



University of Bahrain
College of Information Technology
Department of Information Systems
ITCY460 - Security Risk Assessment and Countermeasures

Group Project: Risk Assessment Plan

Meridian FinTech Solutions

Second Semester 2025/2026

Aljazi Ali Almujaaddam - 202202227
Dana Hussain Alhayki - 202204341
Noora Abdulrahman Bumjaaid - 202203245
Nada Abdulaziz Yahya - 202203864
Maram Abdulqawi Ghaleb - 202305067

Table of Contents:

Table of Contents:	2
1. Introduction	3
2. Risk assessment approach	3
3. Scope and Boundaries	4
3.1 Scope of the Risk Assessment Plan:	4
3.2 Boundaries of the Risk Assessment Plan:	4
4. Assets And Activities	4
5. Threats and vulnerabilities	5
5.1 Key Threat :.....	5
5.2 Key Vulnerabilities:	5
6. Controls	6
6.1 Administrative Controls	6
6.2 Technical Controls	6
6.3 Physical Controls	6
6.4 Assessing Control Efficacy	7
7. Roles	7
7.1 Senior Management	7
7.2 Risk Management/Project Management Teams.....	7
7.3 IT & Security Departments	7
7.4 Department Heads/Business Unit Manager	7
7.5 Employees/Users.....	8
8. Schedule	8
9 . Conclusion	8
10. Appendices	9



1. Introduction

Meridian FinTech Solutions is a firm operating in a cloud-based financial services landscape dependent on important software applications like Pay-API, Fraud-Shield, Currency-X, Wallet-Link, and Fin-Report. Given that such applications handle sensitive financial information as well as multiple external parties, Meridian FinTech Solutions has certain cybersecurity risk exposures that need to be evaluated.

The goal of this risk assessment project is to assess the company's asset exposures, threat and vulnerability analysis, as well as the security controls currently in place by taking a qualitative approach, as outlined in NIST SP 800-30.

2. Risk assessment approach

Meridian FinTech Solutions will utilize an organized qualitative evaluation model for determining the level of risk present within the company's cloud-based system and the financial services environment. This type of evaluation model is best utilized when evaluating Meridian's evolving operational processes as well as the complexity of its dispersed cloud architecture and lack of exact quantitative data. The two components to be assessed through this model are likelihood, the probability a threat will take advantage of a vulnerability and, therefore, exploit it; and impact, the potential harm a threat can cause should it successfully exploit a vulnerability. Both likelihood and impact are scored on a standardized scale (Low, Medium, High) and then combined to create an overall risk rating for each identified scenario. NIST Special Publication 800-30 provides support for qualitative assessments by establishing guidelines and procedures to ensure consistent qualitative evaluations of threats, vulnerabilities, and impacts. The qualitative assessment process includes identifying key assets, analyzing threats and vulnerabilities, assessing current controls, and determining the overall risk. This will allow Meridian to identify specific risks to prioritize mitigation strategy options based upon risk acceptance criteria, or to transfer those risks.

Also, Meridian will be able to verify that the CIA Triad has been applied to all of Meridian's systems, whether cloud systems, APIs, BYOD, or other decentralized communication platforms.

3. Scope and Boundaries

3.1 Scope of the Risk Assessment Plan:

The scope of this risk assessment shall cover all security risks associated with Meridian FinTech Solutions' cloud infrastructure and critical service platforms. The scope shall also include all critical infrastructure that runs on the cloud platforms, such as the AWS Availability Zones and GCP failover platform. Among the critical systems that may be covered under the scope are key platforms such as Pay-API, Fraud-Shield, Currency-X, Wallet-Link, Fin-Report, and the Golden Record database, as these platforms are important in processing sensitive information and financial transactions. Systems where employees have access, for example, through their personal laptops, may also be included in the scope of risk assessment.

3.2 Boundaries of the Risk Assessment Plan:

This risk assessment does not cover external systems or those that are not under the direct management of Meridian FinTech Solutions. These would include retailer systems integrated using the Pay-API and the partner banks that are linked with the Currency-X platform.

Other excluded items would include customer-owned devices accessing Wallet-Link applications. However, risks associated with internal shadow IT communications within the company will be covered in this risk assessment.

4. Assets And Activities

Meridian FinTech Solutions is a cloud native financial service company that has multiple asset locations on both Amazon Web Services (AWS) and Google Cloud Platform (GCP). The core assets of Meridian, which include: Pay-API, Fraud-Shield, Currency-X, Wallet-Link, and Fin-Report, allow for the execution of fundamental business processes and functions, including, but not limited to, processing payments in real-

time, detecting potential fraudulent transactions in real-time, facilitating foreign currency exchanges, integrating mobile wallets into applications, and providing regulatory filing capabilities. In addition to the sensitive nature of the core service's data assets (including the Golden Record database and all transaction logs), Meridian also maintains sensitive information regarding employees' personal identifiable information through the use of their workforce computers and mobile devices used by employees for Bring Your Own Device (BYOD) purposes. This combination of data assets, core services, and supporting infrastructure provides the base upon which Meridian conducts its operations and thus will be used to identify areas of risk that can be assessed and mitigated.

5. Threats and vulnerabilities

The Cloud-based Infrastructure of Meridian, Global Operations, and Mobile Workforce all create many risks. Therefore, each of these risks will need to be assessed in order to protect Meridian's Financial Data, Maintain Compliance with Applicable Laws and Regulations, and protect the Continuity of Meridian's Business. Appendix A identifies the Threats/Vulnerabilities facing Meridian and rates their Likelihood/Impact so that they can be properly mitigated.

5.1 Key Threat:

The major threat to Meridian is the internal threat caused by its use of Hard-coded API Keys; external threats (DDoS, Ransomware, Phishing); and increasing Business Email Compromise (BEC) attacks in Tokyo. Shadow IT practices reveal sensitive conversations that are occurring at the company; the company's physical layout of an open office increases the likelihood of a laptop being stolen or a visitor gaining unauthorized access to all locations globally.

5.2 Key Vulnerabilities:

Poorly managed API keys with weak authentication and authorization; poorly secured Bring Your Own Device (BYOD) devices; poor configuration of Cloud Resources; lack of a Single Sign On / Identity

Management system; lack of a Centralized Security Information and Event Management (SIEM) Solution to provide visibility into potential threats. Employees will continue to be susceptible to phishing attacks and social engineering tactics. Lack of Physical Security measures to prevent employee personal mobile devices from becoming a gateway for unauthorized access and compromised Data.

6. Controls

Controls are measures taken to help prevent or identify a threat, as well as to react to it, which can help to reduce the risk and improve the overall security by using administrative, technical, and physical methods. Appendix B identifies risks with the proper controls that would help to address each risk.

6.1 Administrative Controls

Administrative Controls are in place to help reduce the risk of Social Engineering Attacks by implementing policies that address issues such as Acceptable Use, Bring Your Own Device (BYOD), Access Control, Employee Training, On-Boarding Procedures, and Termination Procedures.

6.2 Technical Controls

The technical control systems include firewalls, intrusion prevention/detection systems (IDS/IPS), encrypted communication protocols, and logging mechanisms with a Security Information and Event Management System (SIEM), which collects and analyzes log entries from various system components to provide incident detection and event reporting.

6.3 Physical Controls

The main focus of physical controls is to protect the facility and all devices from being stolen, damaged, or accessed by unauthorized individuals. These controls are implemented using various methods, including but not limited to: Access Control (who enters/leaves a building), Surveillance cameras, and Securing Company Equipment.

6.4 Assessing Control Efficacy

Controls will be evaluated on their effectiveness in reducing risk, fixing vulnerabilities, and meeting industry standards such as ISO 27001 and NIST 800-30 in order to identify areas where enhancements may need to occur.

7. Roles

Senior management and various departments within Meridian support assessing and addressing cloud system risks.

7.1 Senior Management

Provide an overarching strategic vision for the organization, fund and oversee the project, and make final decisions regarding mitigating identified risks.

7.2 Risk Management/Project Management Teams

Responsible for overseeing that the risk assessment process follows the methodologies, remains on track with respect to the scope of the project, and is completed by the deadline; they also provide reports of their findings.

7.3 IT & Security Departments

Assist with all technical aspects of conducting a risk assessment, including identifying assets, vulnerabilities, potential threats, and monitoring systems used in the cloud (i.e., AWS & GCP).

7.4 Department Heads/Business Unit Manager

Identify key assets within their department, ensure that employees are aware of and adhere to established policies, and report incidents as necessary.

7.5 Employees/Users

Adhere to organizational security policies, act responsibly about safe behavior practices, and immediately report any perceived suspicious activities.

7.6 Third-Party Service Providers

Third-party service providers (cloud services) are responsible for protecting the underlying infrastructure.

8. Schedule

The Project Phases and Timeline Schedule Table (Appendix C) illustrates the planning process of conducting a project for six weeks. The table includes various stages of a project that correspond to certain periods of time during which particular activities need to take place. Overall, such a table allows illustrating how the whole project process is supposed to look from its very beginning to its completion. Every phase of the project has its own tasks and schedule, thus allowing clarifying everything for the team involved in completing the project in question. Additionally, it facilitates a better understanding of what needs to be done within every week.

9 . Conclusion

In conclusion, Meridian FinTech Solutions is at risk of facing numerous security problems due to being entirely reliant on cloud services and technology. Through the implementation of the steps suggested by the NIST SP 800-30, Meridian will be able to gain insight into its vulnerabilities and manage them effectively through appropriate measures. It will ensure the safety of data and decrease any possible losses financially or operationally. Overall, applying these improvements will support secure operations and help the company continue growing safely

10. Appendices

Appendix A: Table 1: Risk Assessment Alignment

The Table above shows the risks/threats that are facing Meridian with respect to likelihood (L), impact (I), and overall risk (OR). This will provide a qualitative analysis to allow Meridian to identify high-risk (Insider Threats; Business Email Compromise; BYOD Weaknesses; Cloud Misconfiguration; Shadow IT; Physical Security Gaps) and to determine which would be the most effective to mitigate, and to assess controls according to ISO 27001 and NIST SP 800-30 Standards to increase Meridian's overall resilience and compliance.

Threat / Vulnerability	Likelihood	Impact	Risk Rating	Notes (Scenario Context)
Hard-coded API key (insider threat)	High	High	Critical	A terminated developer may retain backdoor access via Wallet-Link source code.
Business Email Compromise (Tokyo)	High	Medium	High	400% increase in BEC attempts targeting accounts payable.
BYOD unpatched devices	Medium	High	High	Employee-owned phones with shadow IT apps (Telegram/Slack) create exposure.
Cloud misconfigurations (IAM roles, buckets)	Medium	Medium	Moderate	Misconfigured AWS/GCP resources could lead to privilege escalation.

Lack of centralized SIEM	Low	High	Moderate	No unified log correlation between AWS and GCP reduces visibility.
Shadow IT communications	Medium	Medium	Moderate	Sensitive architectural discussions on personal messaging apps.
Human factors (phishing/social engineering)	High	Medium	High	Employees are vulnerable to phishing; the Tokyo office has already been targeted.
External attacks (DDoS, ransomware)	Medium	High	High	Cloud services are exposed to large-scale external threats.
Physical Security Weaknesses	Medium	High	High	Open office layout and global hubs increase the risk of device theft or unauthorized access to workforce equipment.

Appendix B:Table2: Controls Alignment

This table relates meridian's identified threats/vulnerabilities (qualitative analysis) to potential administrative, technical, and/or physical controls that mitigate those risks. All of these controls relate to one or more of the risks listed above. Each of these controls will be evaluated by an independent reviewer to ensure they meet the requirements of both NIST SP 800-30 and iso 27001 and identify opportunities for improvement.

Threat / Vulnerability	Control Type	Proposed Control(s)
Hard-coded API key (insider threat)	Administrative / Technical	Secure coding standards, automated secret scanning, API key rotation, strict termination procedures, and access revocation.
Business Email Compromise (Tokyo)	Administrative	Phishing awareness training, financial approval workflows, advanced email filtering, and incident response playbooks.
BYOD unpatched devices	Administrative / Technical	BYOD policy enforcement, Mobile Device Management (MDM), endpoint security, mandatory patching, and encryption.
Cloud misconfigurations (IAM roles, buckets)	Technical	IAM role reviews, automated compliance checks, least-privilege access, and CIS benchmark enforcement.
Lack of centralized SIEM	Technical	Deploy a centralized SIEM solution, integrate AWS/GCP logs, and enable real-time monitoring and alerts.
Shadow IT communications	Administrative	Enforce approved collaboration tools, awareness campaigns, and monitoring of unauthorized apps.
Human factors (phishing/social engineering)	Administrative	Security awareness training, simulated phishing campaigns, and stronger MFA enforcement.

External attacks (DDoS, ransomware)	Technical	DDoS protection (AWS Shield), endpoint detection and response (EDR), regular backups, firewalls/IDS/IPS.
Physical Security Weaknesses	Physical	Office access control systems, surveillance cameras, visitor management, and securing workforce devices (MacBooks, BYOD phones).

Appendix C: Table 3: Project Phases and Timeline Schedule

Below there is provided the schedule table of conducting the project under discussion. As seen from Table 3, all project stages (Planning, Asset Identification, Threat & Vulnerability Analysis, Risk Assessment, Controls Evaluation, and Reporting) last for six weeks. Moreover, the table shows what tasks are fulfilled within every phase and how long time it takes to do it. Generally, the table provides information concerning project phases' flow

Phase	Week	Activity (What will be done)	Responsible Party	Description	Duration	Resources
Planning	Week 1	Define scope, objectives, and methodology	Project Manager & Risk Team	Set the foundation of the assessment based on NIST SP 800-30	Mar 25 – Mar 31	Project plan, NIST guidelines
Asset Identification	Week 2	Identify critical assets (AWS, GCP,	IT & Security Team	Document all important systems and	Apr 1 - Apr 7	Asset inventory tools, cloud

		applications, data)		data used by Meridian		dashboards
Threat & Vulnerability Analysis	Week 3	Identify threats (API key issue, BEC, Shadow IT) and vulnerabilities	Security Team	Analyze internal and external risks affecting the system	Apr 8- Apr 14	Security reports, logs
Risk Evaluation	Week 4	Assess likelihood and impact (Low, Medium, High)	Risk Team	Determine overall risk levels for each identified issue	Apr 15- Apr 21	Risk matrix, assessment tools
Control Assessment	Week 5	Evaluate existing controls (MFA, missing SIEM)	IT & Security Team	Identify gaps in current security controls	Apr 22- Apr 28	Security tools, audit reports
Reporting	Week 6	Prepare final report and recommendations	Project Team	Document findings and suggest mitigation strategies	Apr 29 - May 5	Documentation tools